PRADITA University

IT40813 · IT Governance, Risk & Compliance

Lanskap Regulasi dan Kewajiban Kepatuhan

Pertemuan 03

Alfa Yohannis



Isi Pertemuan

PRADITA University

1. Tujuan dan Konteks
2. Membaca Regulasi
3. PDP dan Sistem Elektronik
4. Sektor Kesehatan
5. Siber dan IIV
6. Mitra: OJK dan SPBE
7. Register Kewajiban
8. Aktivitas dan Penutup

PRADITA University

Aturan baru terbit. Siapa yang harus bertindak?

Tujuan Pembelajaran

PRADITA University

- Mengidentifikasi regulasi dan standar yang mengikat sebuah organisasi berdasarkan sektor, jenis data, dan model bisnisnya.
- Menurunkan pasal regulasi menjadi kewajiban yang dapat diperiksa, lengkap dengan pemilik dan buktinya.
- Membedakan kewajiban hukum, kewajiban kontrak, dan standar sukarela beserta akibat pelanggarannya.

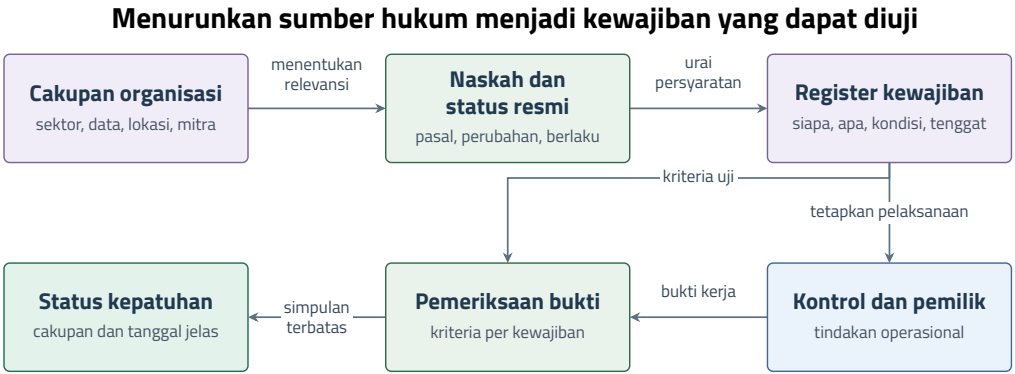
Masalah: Aturan Ada, Pemilik Tidak Ada

PRADITA University

- Misalkan tautan berita aturan baru beredar di grup pesan. Direktur pelayanan mengira urusan TI, kepala TI menunggu fungsi hukum, fungsi hukum menunggu daftar sistem.
- Tiga bulan kemudian, belum ada yang membaca naskahnya.
- Unit layanan menganggap penyimpanan rekam medis tugas vendor. Kontrak tidak menjelaskan bukti cadangan dan pemulihan.
- Saat audit datang, kedua pihak menunjukkan dokumen yang berbeda.
- Bab ini bukan nasihat hukum. Tafsir ditandai “penafsiran bab ini”.

Diagram Konsep Bab 3

PRADITA University



Retensi, cadangan, interoperabilitas, dan pelaporan adalah kewajiban berbeda. Satu sertifikat tidak menggantikan pemeriksaan cakupan.

PRADITA University

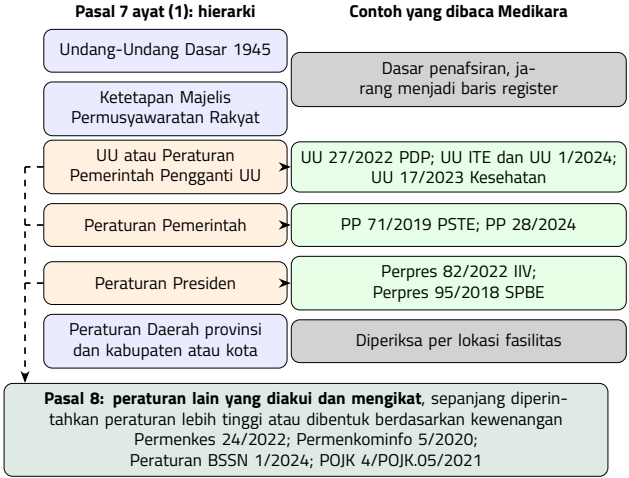
Membaca Regulasi Indonesia

Mulai dari Cakupan Organisasi

Pertanyaan	Keadaan Medikara	Titik awal penelusuran
Sektor	Kesehatan swasta, 36 fasilitas	UU 17/2023, PP 28/2024, Permenkes 24/2022
Jenis data	Data kesehatan, sekitar 1,2 juta kunjungan per tahun	UU PDP, data pribadi spesifik
Lokasi	Sistem di rumah sakit, rencana *cloud*, vendor	PP 71/2019, PP 28/2024, Pasal 56 UU PDP
Model bisnis	Medikara+: 28.000 janji temu per bulan	PP 71/2019, Permenkominfo 5/2020
Mitra	BPJS Kesehatan, SATUSEHAT, asuransi, instansi	Kontrak, aturan mitra, integrasi

Pasal 3 Permenkes 24/2022 menyebut klinik, rumah sakit, apotek, laboratorium. Register yang hanya mencatat rumah sakit melewatkan 31 dari 36 fasilitas, sekitar 86 persen.

Hierarki: Pasal 7 dan Pasal 8 UU 12/2011



Status di JDIH: Dua Contoh

- Periksa nomor, tanggal berlaku, perubahan, pencabutan, dan putusan. Belum ditemukan berbeda dari tidak berlaku.
- Permenkes 24/2022 merujuk UU 29/2004, yang dicabut UU 17/2023.
- Pasal 453 UU 17/2023 menjaga peraturan pelaksana lama sepanjang tidak bertentangan. JDIH BPK mencatat status berlaku (31 Oktober 2026).
- PP 33/2026: BPOM menyebut diundangkan 16 Juli 2026. Basis data nonresmi menyebut mulai berlaku 16 Januari 2027, sisa 77 hari.
- Naskah resmi belum diperoleh, jadi dicatat sebagai pemantauan, bukan tenggat.

PRADITA University

Pelindungan Data Pribadi dan Sistem Elektronik

UU PDP: Peta Pasal, Rincian di Bab 7

Pasal	Isi ringkas	Register	Rincian
Pasal 4	Data kesehatan termasuk data spesifik	Kolom cakupan	Bab 7
Pasal 20	Dasar pemrosesan	K-16	Bab 7
Pasal 39	Mencegah akses tidak sah	K-01	Bab 6, Bab 7
Pasal 46	Pemberitahuan tertulis 3×24 jam	K-04	Bab 7
Pasal 56	Transfer ke luar wilayah hukum	K-13	Bab 7
Pasal 57	Sanksi administratif	Kolom akibat	Bab ini
Pasal 74	Masa penyesuaian 2 tahun	Catatan status	Bab ini

Putusan MK 151/PUU-XXII/2024 mengubah makna Pasal 53 ayat (1) huruf b. Status mencakup putusan.

PP 71/2019 dan Permenkominfo 5/2020

PRADITA University

- PP 71/2019 Pasal 2 membedakan PSE lingkup publik dan privat.
- Pasal 6: pendaftaran sebelum sistem mulai digunakan.
- Pasal 24 ayat (3): gangguan serius akibat pihak lain dilaporkan dalam kesempatan pertama.
- Permenkominfo 5/2020 Pasal 7 ayat (2): pemutusan akses bagi PSE yang tidak mendaftar.
- Penafsiran bab ini: Medikara+ termasuk lingkup privat.

Analogi dan Contoh Berangka

- Analogi: kerusakan kendaraan perlu laporan ke pemilik, asuransi, dan petugas jalan.
- Varian uji kontrak: misalkan kontrak vendor 12 jam, vendor melapor setelah 30 jam. Terlewati 18 jam, sisa 42 dari 72 jam Pasal 46.
- 28.000 janji temu per bulan berarti 336.000 per tahun. Lokasi server utama belum menjelaskan seluruh pemrosesan.
- Pasal 57: denda paling tinggi 2 persen. Misalkan variabel Rp500 miliar, batas atas Rp10 miliar.
- Pasal 74: masa penyesuaian berakhir 17 Oktober 2024, sebelum insiden vendor 2025.

Kasus Medikara: Siapa PSE Medikara+?

PRADITA University

- Misalkan tanda daftar PSE atas nama vendor, lalu pimpinan menganggap seluruh kewajiban pindah.
- Kesimpulan itu mencampur dua pertanyaan: siapa mendaftar, dan siapa pengendali data.
- PP 28/2024 Pasal 962: penyelenggara Sistem Informasi Kesehatan merupakan pengendali data pribadi.
- UU PDP Pasal 37: pengendali mengawasi pihak yang terlibat dalam pemrosesan.
- Tim mencatat K-10 dan K-16, lalu meminta tinjauan fungsi hukum.

PRADITA University

Regulasi Sektor Kesehatan

Rantai Tiga Tingkat

Aturan	Pasal	Isi ringkas
UU 17/2023	296, 297	Tanggung jawab fasilitas; kerahasiaan; akses pasien
PP 28/2024	779, 781	Wajib elektronik; integrasi dengan sistem nasional
PP 28/2024	966, 972	Pusat data di Indonesia; transfer dengan izin Menteri
Permenkes 24/2022	20, 21	Keamanan, cadangan; terhubung platform kementerian
Permenkes 24/2022	22	Kerja sama dengan PSE berfasilitas dalam negeri
Permenkes 24/2022	39, 42	Simpan paling singkat 25 tahun; sanksi administratif

Pasal 45 Permenkes 24/2022: batas penyelenggaraan 31 Desember 2023 sudah lewat.

Empat Kewajiban yang Sering Tertukar

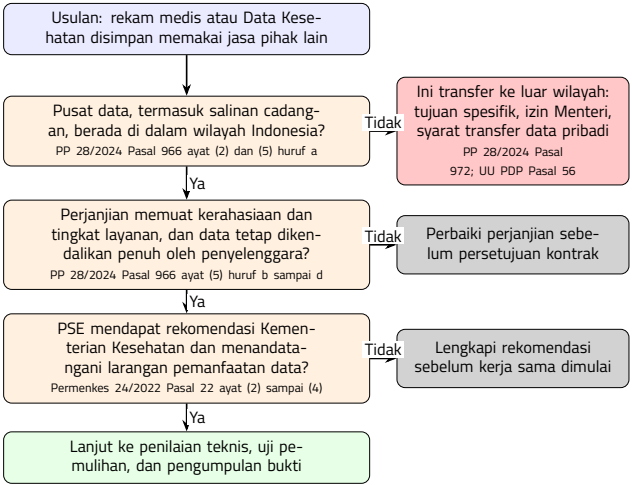
PRADITA University

- Retensi: berapa lama data dipertahankan.
- Cadangan: bagaimana data dipulihkan saat salinan utama rusak.
- Interoperabilitas: apakah data sampai dan terbaca di sistem tujuan.
- Pelaporan: siapa perlu diberi tahu ketika ada kejadian.
- Analogi: salinan di lemari kedua membantu saat lemari pertama rusak, tetapi tidak menjamin arsip tetap terbaca sampai akhir masa simpan.

Dua Contoh Berangka

- Misalkan 5 rumah sakit memakai versi SIMRS berbeda. Satu prosedur retensi perlu bukti pada tiap sistem.
- Sekitar 1,2 juta kunjungan per tahun selama 25 tahun berarti sekitar 30 juta catatan.
- Kunjungan terakhir 2 Maret 2026 berarti batas simpan paling singkat 2 Maret 2051.
- Misalkan klinik mengirim 1.000 catatan dan 40 ditolak platform, atau 4 persen.
- Di 18 klinik, 720 dari 18.000 catatan perlu ditelusuri.

Bolehkah Disimpan di Luar Negeri?



Kasus Medikara: Lapis Kewajiban

- Misalkan vendor menawarkan penyimpanan luar negeri Rp420 juta per tahun, dari Rp600 juta. Hemat Rp180 juta, atau 30 persen.
- Kontrak Rp420 juta melewati batas Rp400 juta pada Bab 2, sehingga naik ke direksi.
- Usulan berhenti pada pertanyaan pertama: pusat data di dalam wilayah Indonesia?
- Harga lebih rendah bukan alasan menerima desain sebelum kewajiban sektor dinilai.
- Pilihan: tawar ulang fasilitas dalam negeri, atau pisahkan data bukan rekam medis setelah dinilai.

PRADITA University

Keamanan Siber Nasional dan Infrastruktur Informasi Vital

Sektor Berbeda dari Penetapan Sistem

PRADITA University

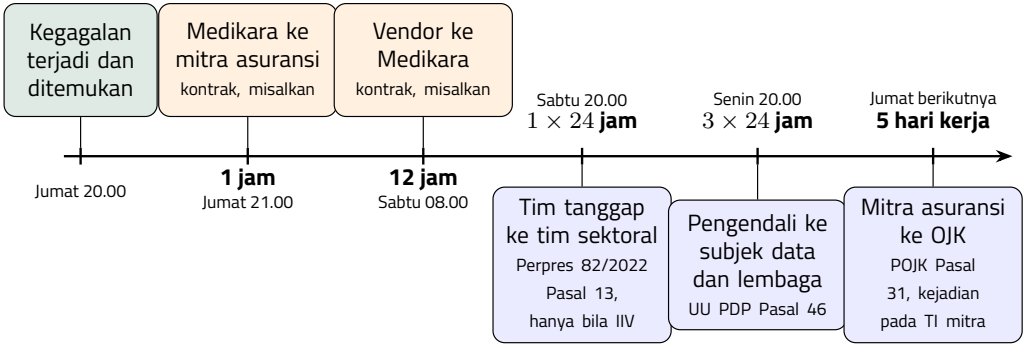
- Perpres 82/2022 Pasal 4: kesehatan termasuk sektor IIV.
- Pasal 6: identifikasi paling sedikit 1 kali setahun, dilaporkan, diverifikasi, lalu ditetapkan.
- Peraturan BSSN 1/2024 Pasal 7 dan 8: penyelenggara membentuk tim tanggap insiden organisasi.
- Pasal 15: insiden paling sedikit berisiko tinggi dilaporkan; 1×24 jam bila terjadi pada IIV.
- Sistem Medikara tidak diasumsikan sudah ditetapkan sebagai IIV.

Analogi dan Dua Contoh

PRADITA University

- Analogi: masuk kawasan rawan banjir tidak berarti setiap bangunan berisiko sama.
- Misalkan pendaftaran berhenti dua jam di 1 dari 18 klinik. Tim mengklasifikasikan dampak dulu.
- Di bawah risiko tinggi: tidak masuk Pasal 15 ayat (3), tetapi tetap dicatat.
- Misalkan 5 rumah sakit dan sekitar 640 dokter bergantung pada satu layanan identitas.
- Ketergantungan itu masuk bahan identifikasi tahunan Pasal 6.

Satu Kejadian, Beberapa Jam



Asumsi sama dengan Bab 7: kejadian dan penemuan bersamaan. Skala tidak proporsional. Angka kontrak adalah pengandaian.

Kasus Medikara: Insiden dan Jam Lapor

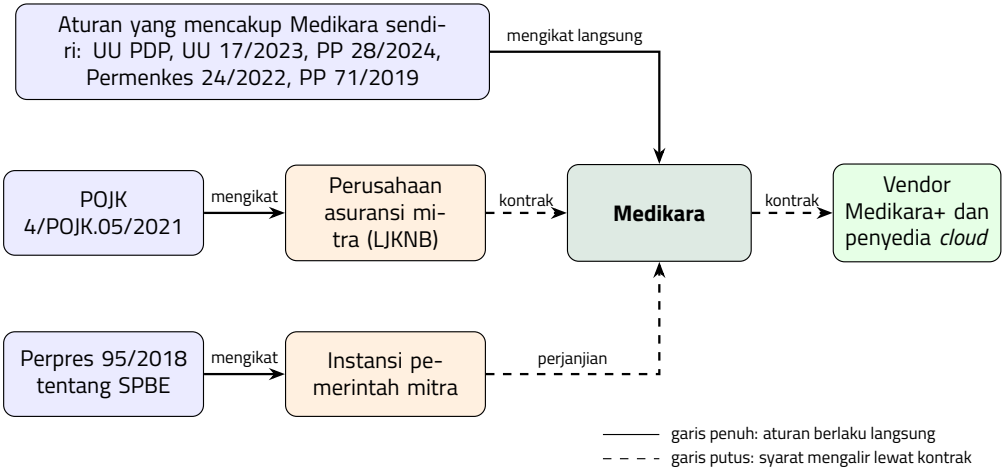
- Varian uji kontrak: vendor menemukan akun dipakai di luar penugasan Jumat 20.00, memberi tahu Minggu 02.00.
- Kontrak 12 jam terlewati 18 jam. Batas Pasal 46 Senin 20.00, tersisa 42 jam.
- Koordinator membuka K-04, K-05, dan K-09. Satu laporan tidak dipakai untuk semua penerima.
- Data latihan Bab 1: 8 malam, baru diketahui hari ke-11. Rentang 72 jam setara 3 hari.
- Tim mencatat waktu kejadian dan waktu diketahui; fungsi hukum menetapkan batas konservatif. PP 33/2026 Pasal 114 ayat (2) hanya dipantau dari salinan pihak ketiga.

Regulasi yang Mengikat Mitra: OJK dan SPBE

Aturan Mitra Tidak Otomatis Berlaku

- POJK 4/POJK.05/2021 Pasal 2: perusahaan asuransi termasuk Lembaga Jasa Keuangan Nonbank (LJKNB).
- Pasal 21: LJKNB tetap bertanggung jawab dan mengawasi penyedia jasa TI.
- Pasal 31: kejadian kritis dilaporkan paling lambat 5 hari kerja setelah diketahui.
- Perpres 95/2018 Pasal 70: evaluasi SPBE ditujukan bagi instansi pusat dan pemerintah daerah.
- Menerima klaim tidak mengubah rumah sakit menjadi lembaga jasa keuangan.

Mengikat Langsung atau Lewat Kontrak



Analogi dan Dua Contoh

- Analogi: pemasok makanan ke sekolah tidak menjadi sekolah, tetapi kontraknya dapat lebih ketat.
- Misalkan mitra asuransi meminta laporan gangguan dalam satu jam.
- Misalkan dari 12 gangguan terakhir hanya 2 tepat waktu, sekitar 17 persen. Statusnya tidak memenuhi.
- Pilihannya: perbaiki deteksi atau tawar ulang klausul.
- Misalkan rumah sakit pemerintah meminta format bukti tertentu. Tim menelusuri dasarnya dulu.

Akibat Pelanggaran Menurut Sumber

Sumber	Akibat
UU PDP Pasal 57	Peringatan, penghentian sementara, penghapusan data, denda paling tinggi 2 persen
PP 71/2019 Pasal 100	Teguran, denda, penghentian sementara, pemutusan akses, dikeluarkan dari daftar
Permenkes 24/2022 Pasal 42	Teguran, rekomendasi pencabutan atau pencabutan status akreditasi
Kontrak mitra (misalkan)	Denda layanan, kewajiban perbaikan, penghentian kerja sama
Standar sukarela (misalkan)	Temuan audit, pembekuan atau pencabutan sertifikat

Kewajiban hukum tidak dapat dihapus lewat kesepakatan vendor. Standar yang disebut dalam perjanjian menjadi kewajiban kontrak.

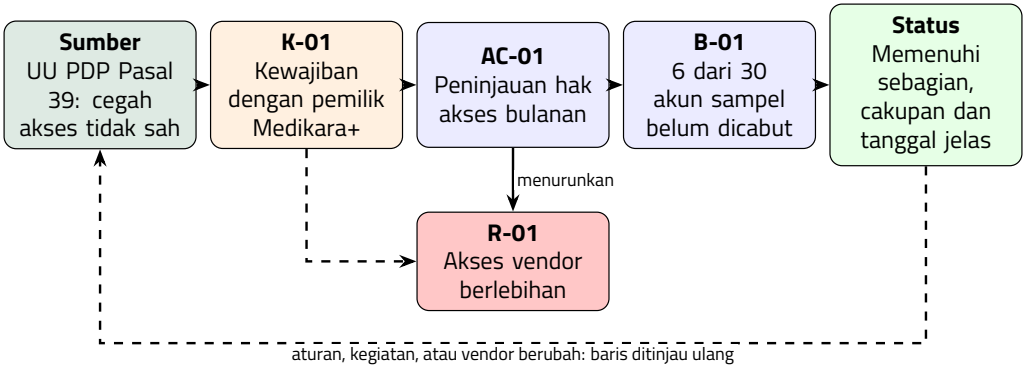
Register Kewajiban Kepatuhan

Register: Siapa, Apa, Kapan, Bukti

PRADITA University

- Satu pasal dapat menjadi beberapa baris. Satu kontrol dapat mendukung beberapa kewajiban.
- ISO 37301:2021 memberi kerangka sistem manajemen kepatuhan. Register adalah salah satu alatnya.
- Analogi: daftar pindah kantor berguna bila tiap tugas punya pemilik, tenggat, dan tanda terima.
- Register contoh, 16 baris: 2 terverifikasi memenuhi, 4 memenuhi sebagian, 2 tidak memenuhi, 7 belum diverifikasi, 1 tidak berlaku.
- Sebanyak 7 baris, atau sekitar 44 persen, belum berbukti. Sisanya tidak otomatis patuh.

Jejak Satu Baris Register



Bab 1: 6 dari 30 akun sampel belum dicabut; peninjauan berikutnya mencabut 24 dari 120 akun.

Satu Pasal, Tiga Hal yang Diuji

Unsur pasal	Tindakan yang diuji	Bukti
Tempat berbeda	Cadangan di luar lokasi tiap fasilitas	Inventaris lokasi cadangan
Periodik	Cadangan berjalan sesuai jadwal	Catatan cadangan dan uji pemulihan
Prosedur tertulis	Prosedur ditetapkan tiap fasilitas	Prosedur operasional yang disahkan

- Sumber: Pasal 20 ayat (4) dan (5) Permenkes 24/2022.
- Misalkan satu uji pemulihan per fasilitas per triwulan: 36 fasilitas, 144 uji setahun.
- Angka itu menjadi dasar menilai beban kerja 52 staf TI.

Contoh Register dan Batas Sertifikat

ID dan dasar	Pemilik dan tindakan	Bukti serta status
K-01, UU PDP Pasal 39	Pemilik Medikara+ mencegah akses tidak sah	Hasil AC-01; memenuhi sebagian
K-02, Permenkes Pasal 20	TI dan rekam medis menguji cadangan	Laporan uji; belum diverifikasi
K-03, Permenkes Pasal 39	Rekam medis menjaga retensi	Jadwal retensi; memenuhi sebagian
K-04, UU PDP Pasal 46	Pengendali menyiapkan pemberitahuan	Kronologi, salinan; belum diverifikasi
K-05, kontrak vendor	Pengelola vendor menagih laporan 12 jam	Rekam komunikasi; tidak memenuhi
K-15, POJK Pasal 31	Analis regulasi mencatat alasan	Pasal 2 POJK; tidak berlaku

ISO/IEC 27001 menilai sistem manajemen dalam ruang lingkup tertentu. Satu sertifikat tidak menggantikan pemeriksaan cakupan.

Aktivitas: Register Kewajiban

PRADITA University

Tujuan: daftar kewajiban yang jelas cakupan, pemilik, dan buktinya.

- Analis regulasi memimpin pembacaan pasal.
- Pemilik konteks menetapkan fungsi pemilik.
- Analis teknologi menilai implikasi sistem.
- Analis risiko menuliskan konsekuensi dan keterkaitan skenario.
- Register minimal: UU PDP, rekam medis elektronik, PSTE, SATUSEHAT, pelaporan insiden siber.

Aktivitas: Langkah dan Penilaian

PRADITA University

- Tentukan cakupan, lalu periksa sumber resmi dan status tiap aturan.
- Pilih sedikitnya 10 kewajiban. Isi pemilik, kondisi, tenggat, bukti, status, dan ID kontrol.
- Tinjau silang satu baris: pemeriksa menyimpulkan status tanpa menebak maksud penulis.
- Luaran masuk C1, dipakai ulang pada Bab 5, Bab 7, dan Bab 12. Berkas: `sources/chapter03/`.
- Nilai: cakupan dan sumber 30 persen, dapat diuji 30 persen, pemilik dan bukti 25 persen, konsistensi status 15 persen.

Ringkasan

- Kepatuhan dimulai dari cakupan, bukan dari daftar sertifikat: 36 fasilitas, bukan 5 rumah sakit.
- Naskah resmi, status, putusan, dan ketentuan penutup dibaca bersama.
- Retensi, cadangan, interoperabilitas, dan pelaporan adalah kewajiban berbeda. Batas 3×24 jam tidak sama dengan 1×24 jam.
- Hukum membawa sanksi, kontrak membawa akibat perjanjian, standar mengikat karena dipilih.
- Kewajiban baru dapat diperiksa setelah organisasi menjelaskan pekerjaan dan cara membuktikannya.

Latihan dan Bacaan

1. Sebuah klinik mitra menyimpan rekam medis di layanan *cloud* luar negeri. Kewajiban apa saja yang perlu diperiksa, dan pada peraturan mana?
2. Tulis ulang satu pasal UU PDP menjadi kewajiban yang dapat diperiksa auditor: siapa melakukan apa, kapan, dan apa buktinya.
3. Jelaskan mengapa sertifikat ISO/IEC 27001 tidak otomatis membuktikan kepatuhan pada UU PDP.

Bacaan: UU PDP; PP 28/2024; Permenkes 24/2022; Perpres 82/2022; BSSN 1/2024.